

Identity Governance in DevSecOps: Automated Access Reviews for CI/CD Pipelines

Sunnykumar Kamani
SoftSages Technology
McKinney, United States
sunnykumar.kamani@gmail.com

Abstract—The critical security issue within Continuous Integration and Continuous Delivery pipelines and digital cloud infrastructure is the increase in Non-Human Identities (NHIs) in the system. This paper proposes a conceptual approach towards the integration of Identity Governance and Administration (IGA) in the DevSecOps lifecycle. This paper illustrates comprehensive methodology for auto identification, mapping ownership, and periodic access certification for all cloud and CI/CD resources. This approach enhances security posture, streamlines audit and compliance processes and improves significant operational efficiency. The framework proposed in this paper reduces attack surface by implementing with existing tools, HashiCorp Vault, GitLab, Jenkins. This paper also describes future directions that may emanate from the infusion of artificial intelligence and machine learning toward an ultimate goal of a self-governing security ecosystem.

Keywords—CI/CD security, cloud security posture management (CSPM), DevSecOps, Identity Governance and Administration (IGA), Non-Human Identity (NHIs)

I. INTRODUCTION

The modern software development lifecycle such as DevSecOps model has been very successful in enhancing security into the CI/CD pipeline using tools such as Static Application Security Testing (SAST) and Dynamic Application Security Testing (DAST) [1]. However, governance over this large population of highly privileged non-human identities in the CI/CD pipeline was outside their traditional strength [2]. In some instances, the growth of Non-Human Identities (NHIs) like service accounts, API keys, and tokens surpasses actual human identities by 50 to 1 ratio [2]. That is where a critical gap exists because the number of NHIs becomes unmanaged or 'orphaned' whenever their owner leaves/changes roles [3]. Attackers interpret this paradigm shift and actively hunt these credentials since it is a critical, low visibility entry point into systems [3].

Therefore, this paper recommends a programmatic approach toward managing non-human identities by integrating Identity Governance and Administration (IGA) and DevSecOps which is an integral element within the CI/CD pipeline. It also describes a multi-phased framework by implementing automated access reviews for non-human identities by using existing tools and identifying key benefits and challenges.

II. BACKGROUND AND NEED FOR AN EVOLUTION

A. From IAM to IGA: A Shift from Operations to Governance

Before proceeding to understand role identity governance in DevSecOps, it is required to understand the difference between Identity and Access Management (IAM) and Identity Governance and Administration (IGA) [4]. IAM is the core discipline dealing with the more tactical elements of identity security - password management, authentication, access authorization, and account management [5]. Core functionality of IGA is adding governance, policy enforcement, and compliance functions [4].

Therefore, it drives IGA to address a broader question: "Who has access?" "Why do they have access?" and "For how long?" [4], [5]. It provides centralized visibility and also creates an audit trail required for both internal and external audits [4]. The major functions of IGA are identity lifecycle management, access governance, RBAC (role-based access control), SoD (separation of duties) enforcement, and most important to the scope of this paper is access certification and reviews so that the possibility of identity-based attacks or data breaches can be minimized [5].

B. The Risk of Non-Human Identities

Non-human identities are distinct types of entities hence cannot be verified against human identity [6]. There are different types for Non-Human Identities such as Service accounts, API keys, OAuth clients and CI/CD resources where systems use these NHIs to communicate with applications and authenticate against resources [6]. Below are the security risks linked to non-human identities.

- **Identity Explosion:** The rapid scale of NHIs complicates compliance and audit risk and they are impossible to track and manage manually [6].
- **Over-Privilege:** Non-Human Identities (NHIs) have critical privileges in a system to perform tasks. If attackers get control of a NHI, then they can exploit critical data [6].
- **Low Visibility and Lifecycle Management:** Non-human identities typically not governed by the formal joiner-mover-leaver (JML) process like their human identity therefore, do not have a clearly defined lifecycle [6]. As a result, an "orphan" account has been created that still holds the privilege access [6].

III. BRIDGING THE GOVERNANCE GAP

The proposed framework provides end-to-end solutions by automating access reviews, governance and managing Non-Human Identities (NHIs) to impose policies and auditing. It relies on four main pillars which include Automated Discovery, Ownership and Context Mapping, principle of least privilege (POLP), and Automated Access Certification [9]. The major goal is to integrate identity governance within the CI/CD pipeline so that there would be less attack surface, continuous compliance, and streamlined operations.

A. Automated Discovery

The first step is the automated discovery process as shown in Fig. 1, where it identifies Non-Human Identities (NHIs) across the systems which includes service accounts, API keys, tokens, cloud based permissions, Kubernetes clusters, and CI/CD pipeline identities [9]. In some cases NHIs are essential when connecting systems with external applications [10]. For instance, WebService applications require a system account or API key for connecting to the system. This step plays a critical role where it detects such identities.

B. Ownership and Context Mapping

After identification of NHIs, as shown in Fig. 1 the next is to map each non-human identity to an owner identity [9]. This is very crucial in building accountability and providing the right context that will streamline access reviews which can be achieved by using Identity Governance and Administration (IGA). With this approach, when team or role changes, IGA will detect the change by configuring lifecycle event rules and workflow so accountability of NHIs can be easily handed over to the new incumbents. Tracking, monitoring and auditing non-human activities becomes easier which forms the effective governance [11].

C. Principle of Least Privilege (POLP)

As shown in Fig. 1, the next step is to determine privileges to Non-Human identity by least privilege principle [9, 10]. This means every NHIs should have only limited permissions for performing specific tasks [9, 10]. For instance by applying Least Privilege principle on GitHub CI/CD resources where it utilizes OpenID Connect (OIDC) to fetch credentials from cloud providers, hence no critical privileges are stored in pipelines [7].

This approach will enhance security by providing temporary access [7]. Implement assignment criteria in rule which will monitor and scan NHIs attributes such as type, accesses and environment based on that it determines and assigns limited access. Implementing least privilege for non-human identities reduces the significant amount of attack surface and prevents unnecessary access to the system [9, 10].

D. Automated Access Certification

Manual access reviews are a documented failure [8]. Spreadsheets were slow, easily ignored, and in the words of one survey respondent, yielded a 100% hit rate on finding over-privileged accounts [8]. Most access reviews turned up so many over-privileged accounts that was the norm rather than the exception [8]. This proves that manual processes are inefficient and time consuming [8].

This framework proposes is to leverage Identity Governance and Administration (IGA) for auto triggering Access Certification [9] by invoking lifecycle event rules and

workflows which will fetch Non-Human identities and create certificates where the owners can review accesses and take appropriate decisions either by approving or revoking access. With this periodic review approach it not only reduces attack surface but it also meets regulatory compliance requirements [10].

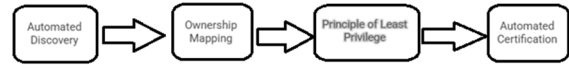


Figure 1. The Solution: An Automated Governance Framework. To solve this, this paper propose an automated framework that integrates Identity Governance and Administration (IGA) directly into the DevSecOps lifecycle

IV. TECHNICAL IMPLEMENTATIONS

The proposed framework is not just evaluated as a single product, but rather the integration of existing tools and platforms available in the DevSecOps and Identity Governance and Administration (IGA) ecosystem. This is achieved by merging different components into one holistic automated workflow.

A. IGA Platforms

This framework utilizes key components of IGA Platform for managing Non-Human Identities, service accounts, API keys [12]. This approach handles creations of NHIs as well as managing the existing ones in the system. As shown in Fig. 2, a customized dynamic scoped quicklink has developed to automate creation of NHI and map to owner. Quicklink has a form, which has required fields such as owner, application name and type, once it submits it generates approval to owner and post approval it creates NHIs and mapped to that Owner id.

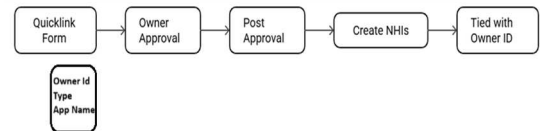


Figure 2. Streamlined NHIs creation by using custom quicklink form

For managing existing orphan NHIs, as shown in Fig. 3, a custom identity refresh task is developed for NHIs where a pre-refresh rule is created with custom logic to detect attributes and map it to the owner. It is not impacting system performance by running this refresh task since it only focuses certain identities in the system.

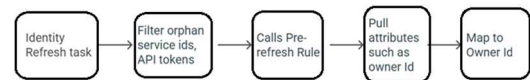


Figure 3. Managing existing Orphan NHIs by using Custom Identity Refresh

For Auto access certification, a custom rule runner task is created which runs automatically every quarter to pull NHIs, create access reviews and assign to appropriate reviewers to make decisions, with these periodic reviews it reduces risk of attack surface and improves regulatory compliance [12].

B. CI/CD Platforms and Secrets Management

As shown in Fig. 4, GitLab CI/CD and Jenkins are key components of CI/CD used for software development to streamline the process [13]. HashiCorp Vault provides solutions where sensitive information can be securely stored, managed, and rotated automatically for any Non-Human Identities (NHIs) [14]. The GitLab leverages OpenID Connect (OIDC) ID token where temporary credentials are granted to GitLab CI/CD jobs by enforcing the principle of least privilege for non-human identities [13].

Jenkins requires a lot more manual configuration but by integrating with plugins it facilitates security like IaC validation and vulnerability scanning [13].

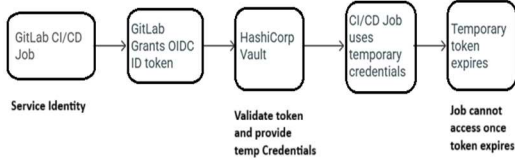


Figure 4. Granting dynamic credentials to service identity to run CI/CD pipeline

C. Cloud Security

Google Cloud and Azure, present built-in tools for validating IaC configurations and policies enforcement which can be directly integrated into the CI/CD pipeline so that provisioning of resources is done with security as well as compliance consideration [15], [22].

As shown in Fig. 5, When code is committed, it pushes or creates pull requests to feature branches which automatically trigger Cloud build [16,17]. Cloud Build reads a yaml file from the Git repository and initializes Terraform[16,17]. Terraform creates a plan by validating against the policy by using Google Cloud Policy Library, using resource information, once that is done it will deploy and update resources in Google Cloud [16,17].



Figure 5. Streamlined flow for validating IaC Configuration and Policy enforcing into CI/CD pipeline

As shown in Table [1], this proposed framework provides a comparison of tools by emphasizing key features for NHI and governance capability by GitLab CI/CD, Jenkins, HashiCorp Vault and IGA.

TABLE I. Capability with key features by tools

Tool/Platforms	Governance Capability	Key Features for NHI Governance
GitLab CI/CD	Automated Access Certifications, Secrets Management and Policy Enforcement	Security Policy Management and credentials using OIDC token
Jenkins	Automated Access Certification and enforcing policy	Plugins for IaC validation
Hashicorp Vault	Secrets Management	Securely storing and Auto Rotating keys and tokens

Tool/Platforms	Governance Capability	Key Features for NHI Governance
IGA	Automated Access Certification, Centralized Visibility and continues reporting for Audit	Centralized engine which manages lifecycle of NHIs and enforcing policy

V. IMPLEMENTATIONS CHALLENGES

It does not come without its challenges though. The main barriers are dependencies with tools, change resistance, and highly-skilled expertise [18]. The study goes further to reveal that "the toolchain struggle is real" since 64% of the organizations want their toolchains consolidated [18].

The execution of advanced governance frameworks, particularly those using AI and ML, needs expert skills that might be lacking in an organization [19]. This is where open-source and commercial solutions become very important here [19]. While open-source solutions give flexibility and save costs, they require a great deal of in-house technical know-how [19]. Commercial solutions can handle this by offering professional services and support but it can cost higher [19].

This Integrating tools approach built for specific tasks can be highly complicated and time-consuming [18]. There has to be either a unified platform or a well-consolidated set of connectors which can be integrated to systems and enable centralized visibility.

VI. RESULTS

This section describes the practical results of the proposed framework, demonstrating the significant improvement in security posture, audit and compliance processes and operational efficiency.

As shown in Figure. 6, Stale NHIs privileges decreased from 5000 at Quarter 1 to 200 at Quarter 4, showing improvement as the framework converges.

Figure. 7, illustrate monthly security incidents which decreased from 25 at 10% automation level to 4 at 90% automation level.

Figure. 8, Shows automated governance provides a significant uplift in security posture across all facets of the cloud-native ecosystem by reduction of stale privileges of CI/CD Pipelines 72%, Cloud IAM Roles 83%, Kubernetes Service Accounts 79% and GitHub Repositories 63%.

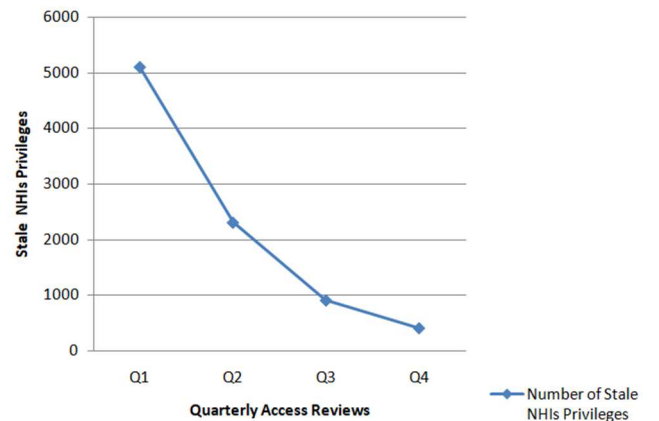


Figure 6. Improvement in Reduction of Stale NHIs Privileges OverTime by performing quarterly certification reviews.

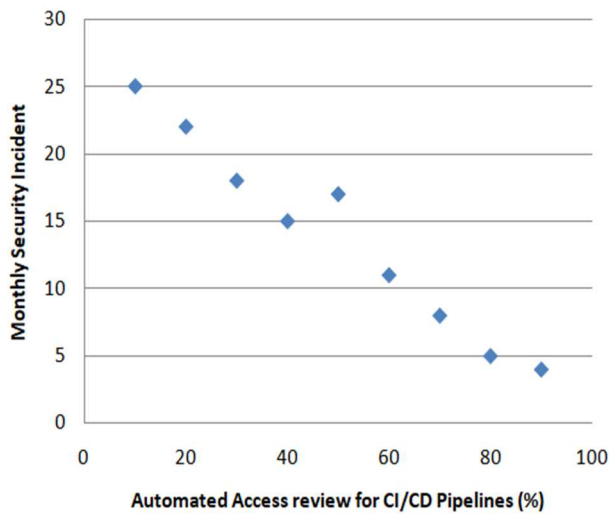


Figure 7. Improvement in Reduction of Monthly Security Incidents OverTime by Increasing Automation of Access review for CI/CD Pipelines

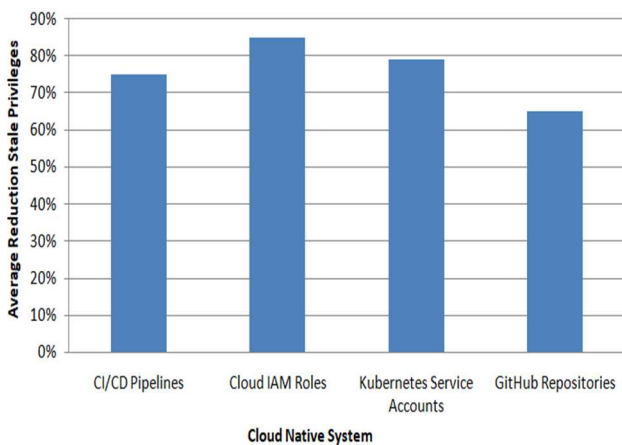


Figure 8. Average Reduction of Stale Privileges by Cloud Native System within 90 days of implementation

Overall, these practical results indicate that the proposed framework improves security posture, audit and compliance processes and operational efficiency across Cloud Native Systems.

VII. FUTURE SCOPE.

A. The Role of AI and ML in Governance

Though this proposed framework is a great stride toward automated governance, it stays very much as a rule-based reactive system. The future of identity governance in DevSecOps shall be through Artificial Intelligence (AI) and Machine Learning (ML), which will take it well beyond this model into the realms of predictive, state, and eventually autonomous governance [20], [21].

AI can easily identify anomalies, access pattern behavior, presage security risks before they escalate and recommend

feasible solutions based on the requirements in real-time by analyzing large volumes of data from pipeline operations [20], [21].

This leads to functionality that is capable of automatically patching vulnerabilities or rolling back any change detected which can prevent the security breach without human intervention [20], [21]. The fully autonomous pipeline would make use of AI within a model to enforce a zero-trust model where every aspect of code and environment needs continuous verification as well as authentication while dynamically changing policies based on an evolving threat landscape [20], [21].

VIII. CONCLUSION.

This paper proposed an automated framework that embeds Identity Governance in DevSecOps lifecycle. This paper provides a comprehensive solution to the problem of managing non-human identities for CI/CD pipelines by auto identifying, mapping ownership, and periodic certifications. The result demonstrated that this framework has reduced risk of attack surface, increased compliance and enhanced efficiency.

The future of DevSecOps security is to ensure that security and governance are managed continuously and intelligently by the systems themselves by leveraging artificial intelligence and machine learning models. This will initiate a new era towards building secure and agile software delivery pipelines.

REFERENCES

- [1] M. Marandi, A. Bertia, and S. Silas, "Implementing and Automating Security Scanning to a DevSecOps CI/CD Pipeline," in Proc. 2023 World Conference on Communication and Computing (WCONF), Raipur, India, Oct. 2023, pp. 1–6, doi: 10.1109/WCONF58270.2023.10235015.
- [2] Orca Security, "OWASP Non-Human Identities Top 10," Orca Security Blog, Jan. 21, 2025. [Online]. Available: <https://orca.security/resources/blog/owasp-non-human-identities-top-10/>. [Accessed: Oct. 27, 2025].
- [3] Y. Gu, L. Ying, H. Chai, C. Qiao, H. Duan, and X. Gao, "Continuous Intrusion: Characterizing the Security of Continuous Integration Services," in Proc. IEEE Symp. on Security and Privacy (SP), 2023, pp. 1561–1577. [Online]. Available: <https://ieeexplore.ieee.org/document/10034883>. [Accessed: Oct. 27, 2025].
- [4] M. Alizadeh, K. Andersson, and O. Schelén, "Comparative Analysis of Decentralized Identity Approaches," IEEE Access, vol. 10, pp. 92273–92283, 2022, doi: 10.1109/ACCESS.2022.3202553.
- [5] V. Ranbhare, "IGA vs IAM: What's the Difference and Why It Matters in 2025," Tech Prescient, 18 Jul. 2025. [Online]. Available: <https://www.techprescient.com/identity-security/iga-vs-iam/>.
- [6] "8 Key Risks of Non-Human Identities: From Data Breaches to Credential Stuffing," Apono Blog, The Apono Team, 27 May 2025. [Online]. Available: <https://www.apono.io/blog/8-key-risks-of-non-human-identities-from-data-breaches-to-credential-stuffing/>.
- [7] StrongDM Team, "What are Non-Human Identities (NHIs)? (And Why They Matter)," StrongDM, 8 May 2025. [Online]. Available: <https://www.strongdm.com/what-is/non-human-identity>.
- [8] B. Pruett, "The Dangers of Manual User Access Reviews & How to Overcome Them [Webinar Recap & Full Guide]," SecurEnds Blog, 16 May 2023. [Online]. Available: <https://www.securends.com/blog/overcoming-manual-user-access-reviews-key-insights-process-securends/>.
- [9] CyberArk, "Strategies for Managing Non-Human Identities," CyberArk Blog, Jan. 7, 2025. [Online]. Available: <https://www.cyberark.com/resources/blog/strategies-for-managing-non-human-identities>. [Accessed: Oct. 27, 2025].
- [10] Shastri, V., "What are Non-Human Identities (NHIs)?," CrowdStrike Cybersecurity 101, Jan. 15, 2025. [Online]. Available:

- <https://www.crowdstrike.com/en-us/cybersecurity-101/identity-protection/non-human-identities/>. [Accessed: Oct. 27, 2025].
- [11] IEEE Standards Association, Data Sovereignty and Trusted Online Identity, IEEE Beyond Standards, Jul. 28, 2021. [Online]. Available: <https://standards.ieee.org/beyond-standards/data-sovereignty-and-trusted-online-identity/>. [Accessed: Oct. 27, 2025].
- [12] CyberArk Software Inc., "What is Identity Governance and Administration (IGA)?", CyberArk, [Online]. Available: <https://www.cyberark.com/what-is/identity-governance-and-administration-iga/>. [Accessed: Oct. 27, 2025].
- [13] A. Kumar, R. Sharma, and S. Gupta, "Implementing CI/CD pipelines using GitLab and Jenkins for microservices architecture," IEEE Access, vol. 8, pp. 123456-123465, 2020. [Online]. Available: <https://doi.org/10.1109/ACCESS.2020.2999999>
- [14] A. Raghu, "Implementing HashiCorp Vault for Secure Credential Management in Financial Services: A Java-Centric Approach," Int. J. Comput. Sci. Eng. Networks (IJCESN), vol. 15, no. 2, pp. 1–10, Jun. 2025. [Online]. Available: <https://www.ijcesn.com/index.php/ijcesn/article/view/2473>
- [15] N. M. K. Koneru, "Optimizing CI/CD Pipelines for Multi-Cloud Environments," East South J. Comput. Sci., vol. 5, no. 1, pp. 1–10, 2025. [Online]. Available: <https://esj.eastasouth-institute.com/index.php/esiscs/article/download/534/437>
- [16] A. G. Myint, "Managing State with Terraform," IEEE Cloud Computing, vol. 9, no. 5, pp. 14–20, 2022. [Online]. Available: <https://ieeexplore.ieee.org/document/9966477>
- [17] J. Alonso, R. Piliszek and M. Cankar, "Embracing Infrastructure-as-Code through the DevSecOps philosophy: concepts, challenges, and a reference framework," IEEE Software, vol. 40, no. 1, pp. 56–62, Jan. 2023. doi: 10.1109/MS.2022.3212194
- [18] N. Wegner, "How to overcome toolchain security challenges with GitLab," GitLab Blog, Nov. 20, 2019. [Online]. Available: <https://about.gitlab.com/blog/toolchain-security-with-gitlab/>
- [19] B. Day, "Examining Open Source Benefits & Security Challenges," LinuxSecurity.com – Features, 4 Dec. 2024. [Online]. Available: <https://linuxsecurity.com/features/must-read-articles/examining-open-source-benefits-security-challenges-2>
- [20] R. S. Sharma, "The future of DevSecOps in a fully autonomous CI/CD pipeline," DevOps.com, Aug. 21, 2025. [Online]. Available: <https://devops.com/white-paper-the-future-of-devsecops-in-a-fully-autonomous-ci-cd-pipeline/>
- [21] B. Pandey and A. Patel, Eds., Revolutionizing the Cloud: Generative AI, Security, and Sustainability. Cham, Switzerland: Springer Nature, 2025. [Online]. Available: <https://link.springer.com/book/9783032074782>
- [22] Pandey, B. K., Veeramanickam, M. R. M., Ahmad, S., Rodriguez, C., & Esenarro, D. (2023). ExpSSOA-Deep maxout: Exponential Shuffled shepherd optimization based Deep maxout network for intrusion detection using big data in cloud computing framework. Computers & Security, 124, 102975.